

Lista de Exercícios: Firewall

Prof. Gabriel Rodrigues Caldas de Aquino

Compilado em:
November 21, 2025

1 Conceitos de Segurança e Estratégia de Defesa

O firewall não é apenas um dispositivo técnico, mas uma peça central na estratégia de segurança da informação da organização.

1. Defina o conceito de **Perímetro de Rede**. Qual é o papel fundamental do firewall em relação às redes "Confiáveis" (Trusted) e "Não Confiáveis" (Untrusted)?
2. A configuração de um firewall deve refletir a **Política de Segurança** da organização. Explique a diferença entre a Política de Segurança (nível estratégico) e as Regras do Firewall (nível técnico). Quem deve ditar quem?
3. O que é **Superfície de Ataque**? Explique como a aplicação de uma política de **Filtro Positivo** no firewall contribui para a **redução** da superfície de ataque da rede.
4. O conceito de **Defesa em Profundidade** baseia-se no uso de múltiplas camadas de segurança. Se uma empresa já possui um firewall de borda robusto, por que ela ainda precisa se preocupar com segurança nos hosts (antivírus, patches, firewalls locais)? Cite uma ameaça que o firewall de borda tipicamente não consegue deter.

2 Tipos de Firewall: Filtros de Pacotes

Os filtros de pacotes representam as gerações iniciais e a evolução para o monitoramento de estado.

1. Defina o funcionamento de um **Firewall com Filtro de Pacotes sem Estado (Stateless)**. Quais informações ele utiliza para tomar decisões?
2. Ainda considerando o **Firewall com Filtro de Pacotes sem Estado (Stateless)** diga uma vantagem e uma limitação do seu uso.

3. Considere o problema de gerenciar o tráfego de retorno quando usando um **Firewall com Filtro de Pacotes sem Estado (Stateless)**. Defina como isso é solucionado ao utilizar um **Firewall com Filtro de Pacotes com Estado (Stateful)**.
4. Defina o que é um **Firewall com Filtro de Pacotes com Estado (Stateful)**.
5. O que é a "Tabela de Estado" e qual a sua função ao decidir se um pacote de entrada (inbound) deve ser aceito ou rejeitado?
6. Ao adicionar uma regra de bloqueio em um **Firewall com Filtro de Pacotes com Estado (Stateful)**, caso a tabela de estado não seja modificada. O que tipicamente acontece com a comunicação que já estava em curso antes de efetuar a adição da regra? Justifique.

3 Firewalls de Aplicação (Proxies)

Os **Firewalls de Aplicação** (também chamados de **Proxies de Aplicação**) operam na camada mais acima da pilha de protocolos TCP/IP.

1. Em qual camada da pilha TCP/IP o **Proxy de Aplicação** opera?
2. Compare os **Firewalls de Aplicação** com Filtros de pacotes com ou sem estados.
3. Devido a esse posicionamento na pilha, o **Firewall de Aplicação** pode inspecionar aspectos que o Filtro de Pacotes (Stateful ou Stateless) não possui? O que ele é capaz de inspecionar que os outros não são? Dê um exemplo prático.
4. Explique como esse posicionamento permite ao **Firewall de Aplicação** realizar proteções contra ataques que exploram vulnerabilidades no software servidor?

4 Lógica de Filtragem e Implementação de Políticas

A definição da política padrão (Default Policy) determina a postura de segurança do firewall.

1. Defina o que é uma política de **Filtro Positivo**.
2. Defina o que é uma política de **Filtro Negativo**.

Considere a tabela de requisitos de serviços abaixo para um Servidor Web Corporativo (IP: 172.16.20.5):

Serviço/Protocolo	Origem	Destino	Permite Acesso
HTTP (TCP/80)	Qualquer IP	Servidor (172.16.20.5)	SIM
HTTPS (TCP/443)	Qualquer IP	Servidor (172.16.20.5)	SIM
SSH (TCP/22)	Admin (10.0.0.100)	Servidor (172.16.20.5)	SIM
FTP (TCP/21)	Qualquer IP	Servidor (172.16.20.5)	NÃO
Outros	Qualquer IP	Servidor (172.16.20.5)	NÃO

Implemente as regras em um firewall com os seguintes campos: *IP de origem*, *Porta de origem*, *IP de destino*, *Porta de destino*, *Ação*.

Tarefas:

3. Implemente um **Filtro Positivo**. Crie uma tabela de firewall com as regras necessárias. Indique qual é a **regra implícita** ao final da lista.
4. Implemente um **Filtro Negativo**. Crie uma tabela de firewall com as regras necessárias. Indique qual é a **regra implícita** ao final da lista.
5. Discuta prós e contras de ambas implementações.

5 Ações de Bloqueio: DROP vs REJECT e Comportamento TCP

Ao definir uma regra de bloqueio, o administrador deve escolher entre descartar o pacote silenciosamente ou informar ao remetente que o acesso foi negado.

1. Explique a diferença técnica entre ações **DROP** (também chamado de Deny ou Discard) e **REJECT**. O que o firewall envia de volta ao remetente em cada caso?
2. No contexto do protocolo TCP, quando uma regra de **REJECT** é acionada, o firewall simula o comportamento de um host final recusando a conexão. Para isso, ele envia um pacote de resposta com uma **Flag TCP** específica ativada. Que Flag é essa?
3. Por que a utilização do **DROP** é considerada uma técnica de "furtividade" (stealth) contra varreduras de porta (port scans)? Explique como o comportamento silencioso afeta a conclusão e o tempo de resposta de um atacante em comparação ao uso do REJECT.